La estadística en la Ingeniería de Sistemas: detección de ataques de fuerza bruta por SSH

1. El papel de la estadística en Ingeniería de Sistemas.

La Ingeniería de Sistemas trabaja con sistemas que generan datos de forma continua: servidores, redes, aplicaciones y bases de datos. Por eso la estadística no es un complemento, sino la herramienta que permite decidir con evidencia y no con intuición. Al investigar cómo se usa en mi disciplina, identifiqué estas aplicaciones principales:

- **Rendimiento y planificación de capacidad:** modelar tiempos de respuesta y llegadas de usuarios para saber cuántos recursos necesita un servicio.
- **Calidad y confiabilidad del software:** estimar la frecuencia de fallos y defectos, y medir si un cambio realmente mejora un sistema.
- **Teoría de colas y simulación:** describir cómo llegan las peticiones a un servidor, algo que suele modelarse con distribuciones como la de Poisson y la exponencial.
- **Analítica de datos y toma de decisiones:** resumir grandes volúmenes de información con medidas descriptivas, intervalos de confianza y pruebas de hipótesis.
- **Seguridad informática:** distinguir el comportamiento normal de un sistema de uno anómalo para detectar intrusiones.

De todas ellas elegí la **seguridad informática**, porque me interesa la ciberseguridad y porque permite aplicar con claridad los temas que he visto en Estadística 1: probabilidad, variables discretas y continuas, distribuciones, bondad de ajuste y pruebas de hipótesis.

2. Selección de la aplicación y formulación del problema

Aplicación seleccionada

Detección de ataques de fuerza bruta contra el servicio SSH de un servidor, a partir del análisis estadístico de los intentos de conexión.

SSH es el servicio que se usa para administrar servidores de forma remota. Cuando está expuesto a internet, recibe intentos automáticos de adivinar usuarios y contraseñas. Un ataque de fuerza bruta consiste en probar muchas combinaciones en poco tiempo. El reto para un ingeniero es saber cuándo el volumen de intentos deja de ser normal y pasa a ser un ataque, y la estadística permite fijar ese criterio de forma objetiva en lugar de usar un umbral a ojo.

Problema

En un servidor expuesto a internet, ¿el número de intentos de conexión SSH por minuto se comporta como una distribución de Poisson en condiciones normales? ¿Cambia de forma significativa durante un ataque de fuerza bruta? ¿Qué umbral de intentos por minuto sería estadísticamente poco probable en condiciones normales y podría usarse como alerta?

Preguntas que queremos responder

1. ¿Los conteos de intentos por minuto se ajustan a una distribución de Poisson?
2. ¿El tiempo entre intentos consecutivos sigue una distribución exponencial?
3. ¿La tasa media de intentos por minuto es distinta entre un periodo normal y un periodo de ataque?
4. ¿A partir de cuántos intentos por minuto un valor es poco probable en condiciones normales?

Datos que se requieren

Variable	Tipo	Para qué la uso
Marca de tiempo de cada intento de conexión	Continua	Calcular el tiempo entre intentos
Número de intentos por minuto	Discreta	Ajustar una distribución de Poisson
Periodo (normal o ataque)	Categórica	Comparar los dos grupos
Etiqueta del tráfico (benigno o ataque)	Categórica	Separar los periodos

Cómo se pueden obtener

Hay dos caminos: recolectar registros propios con un servidor o un honeypot, o usar un conjunto de datos público ya etiquetado. Decidí usar datos públicos para que cualquier persona pueda verificar la fuente y la recolección de datos propios mediante honeypot requiere mucha logística y tiempo para recolectar.

3. Recolección y organización de los datos

Fuente de los datos

Uso el conjunto de datos **CIC-IDS2017**, publicado por el Canadian Institute for Cybersecurity de la Universidad de New Brunswick (Canadá). Es un conjunto público, ampliamente citado en investigación sobre detección de intrusiones, que contiene tráfico de red normal y tráfico de ataques, ya etiquetado.

Según sus autores, el tráfico de fondo se generó perfilando el comportamiento de 25 usuarios sobre los protocolos HTTP, HTTPS, FTP, SSH y correo, y los ataques se ejecutaron sobre una red de víctimas durante cinco días, entre el 3 y el 7 de julio de 2017. Es importante aclarar que se trata de un entorno de pruebas controlado y realista, no del tráfico de un servidor en producción. Lo considero adecuado para este ejercicio porque es abierto, está documentado y tiene los periodos de ataque identificados con su hora exacta.

Periodos que vamos a comparar

- **Periodo normal:** el lunes 3 de julio de 2017, un día que según la documentación solo contiene tráfico benigno.
- **Periodo de ataque:** el martes 4 de julio de 2017, entre las 14:00 y las 15:00, cuando se ejecutó el ataque de fuerza bruta SSH con la herramienta Patator (SSH-Patator).

Archivos que se descargan

El conjunto ofrece los datos como flujos de red: cada fila es una conexión resumida con más de 80 características. Para este trabajo uso el archivo de flujos etiquetados (GeneratedLabelledFlows), que incluye la marca de tiempo de cada flujo, necesaria para contar intentos por minuto.

Organización de los datos

Los datos originales están en archivos CSV con muchas columnas, así que los organizo en una tabla más pequeña y estructurada. Los pasos son:

1. **Cargar** los archivos CSV del lunes y del martes.
2. **Seleccionar las columnas relevantes:** marca de tiempo, puerto de destino, IP de origen, IP de destino y etiqueta.
3. **Filtrar** los flujos dirigidos al puerto 22, que es el de SSH, para quedarme solo con los intentos de conexión a ese servicio.
4. **Limpiar:** convertir la marca de tiempo a formato de fecha y hora, y eliminar filas vacías o inválidas.
5. **Separar los periodos:** el lunes completo como periodo normal, y el martes de 14:00 a 15:00 con etiqueta de ataque SSH como periodo de ataque.
6. **Agrupar por minuto:** contar cuántos intentos hay en cada minuto, y calcular también el tiempo entre intentos consecutivos.s

El resultado son dos tablas listas para el análisis, guardadas en formato CSV:

Tabla	Contenido	Variable estadística
Conteos por minuto	minuto, número de intentos, periodo	Discreta
Tiempos entre intentos	intervalo en segundos, periodo	Continua

Supuestos y limitaciones

- Cada flujo dirigido al puerto 22 lo interpreto como un intento de conexión. Es una aproximación razonable, pero un flujo no es exactamente una línea de registro de autenticación.
- El periodo de ataque dura una hora, por lo que tendré alrededor de 60 observaciones de conteo por minuto en ese grupo, menos que en el periodo normal. Lo tendré en cuenta al elegir y interpretar las pruebas.
- Al ser un entorno de pruebas, los resultados no se pueden generalizar sin cuidado a servidores reales, aunque sí sirven para demostrar la metodología.

4. Cibergrafía

- Canadian Institute for Cybersecurity. *Intrusion detection evaluation dataset (CIC-IDS2017)*. University of New Brunswick. https://www.unb.ca/cic/datasets/ids-2017.html
- Sharafaldin, I., Habibi Lashkari, A., & Ghorbani, A. A. (2018). *Toward generating a new intrusion detection dataset and intrusion traffic characterization*. 4th International Conference on Information Systems Security and Privacy (ICISSP).